

1. Define Computer Security, Network Security and Internet Security

Computer Security - generic name for the collection of tools designed to protect data and to thwart hackers.

Network Security - measures to protect data during their transmission.

Internet Security - measures to protect data during their transmission over a collection of interconnected networks.

2. What security services are provided by X.800?

A service provided by a protocol layer of communicating open systems, which ensures adequate security of the systems or of data transfers

Authentication - assurance that the communicating entity is the one claimed

Access Control - prevention of the unauthorized use of a resource

Data Confidentiality –protection of data from unauthorized disclosure

Data Integrity - assurance that data received is as sent by an authorized entity

Non-Repudiation - protection against denial by one of the parties in a communication

3. Draw the single round structure of DES algorithm.

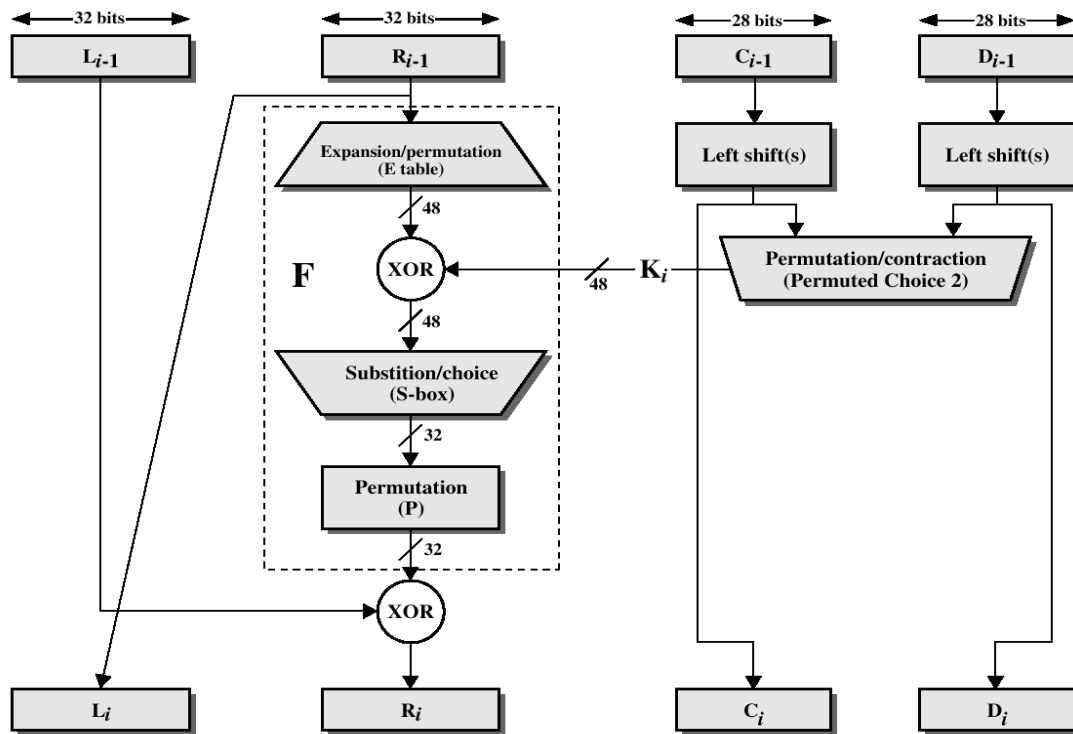


Figure 2.4 Single Round of DES Algorithm

4. What are the difference between

(i) Secret Key Cryptography and Public Key Cryptography

Public Key	Private Key
A published key that can be used to send a secure message to a receiver.	A secret key that can be used to decrypt messages encrypted with the corresponding public or private key.
Asymmetric Encryption	Asymmetric Encryption Symmetric Encryption
probably most significant advance in the 3000 year history of cryptography	traditional secret/single key cryptography uses one key
uses two keys – a public & a private key	shared by both sender and receiver
asymmetric since parties are not equal	if this key is disclosed communications are compromised
uses clever application of number theoretic concepts to function	also is symmetric, parties are equal
complements rather than replaces secret key cryptography	hence does not protect sender from receiver forging a message & claiming is sent by sender

(ii) Block Cipher and Stream Cipher

BLOCK CIPHER	STREAM CIPHER
Converts the plain text by taking its block at a time.	Converts the text by taking one byte of the plain text at a time.
Simple design	Complex comparatively
64 Bits or more	8 Bits
Uses both confusion and diffusion	Relies on confusion only
Reversing encrypted text is hard.	It uses XOR for the encryption which can be easily reversed to the plain text.

5. Define diffusion and confusion in Feistel cipher structure.

- (i) cipher needs to completely obscure statistical properties of original message
- (ii) a one-time pad does this
- (iii) more practically Shannon suggested combining S & P elements to obtain:
- (iv) diffusion – dissipates statistical structure of plaintext over bulk of ciphertext
- (v) confusion – makes relationship between ciphertext and key as complex as possible

6. What is Traffic Padding?

Traffic padding is a function that produces ciphertext output continuously, even in the absence of plaintext. A continuous random data stream is generated. When plaintext is available, it is encrypted and transmitted. When input plaintext is not present, the random data are encrypted and transmitted. This makes it impossible for an attacker to distinguish between true data flow and noise and therefore impossible to deduce the amount of traffic.

7. Describe Meet-in-the-Middle attack on 2DES.

meet-in-the-middle attack

- works whenever use a cipher twice
- since $X = EK_1[P] = DK_2[C]$
- attack by encrypting P with all keys and store
- then decrypt C with keys and match X value
- can show takes $O(256)$ steps

8. What are the requirements of Kerberos?

The following requirements were listed for Kerberos:

Secure: a network eavesdropper should not be able to obtain the required information for impersonating a user.

Reliable: services rely on the availability of Kerberos access control, thus lack of availability of Kerberos is lack of availability of the services. Kerberos should employ a distributed server architecture with one system able to back up another.

Transparent: the user should not be aware that authentication is taking place, except for the entering of the password.

Scalable: the system should have a modular, distributed architecture to support large number of clients and servers.

9. State the summary of Kerberos version 4 final protocol.

We present first a simple authentication dialog and then a more elaborate one to emphasize the need for the many elements in the real Kerberos 4 protocol.

A Simple Authentication Protocol

This protocol uses an authentication server (AS) that knows the passwords of each user. AS also shares a secret unique key with each server.

C -> AS: IDC || PC || IDV

AS -> C: IDC || Ticket

C -> V: Ticket

Ticket = EKV[IDC || ADC || IDV]

C = Client

AS = authentication server

V = server

IDC = identifier of user on C

IDV = identifier of V

PC = password of user on C

ADC = network address of C

KV = secret encryption key shared by AS and V

- In this scenario, user log on to a workstation and requests access to server V. The client module sends a message IDC || PC || IDV to AS, which checks if the password is correct and if the user has permitted access to the requested server.
- If both these pass, then AS creates a ticket containing EKV[IDC || ADC || IDV] that the user can use to apply to V for service.
- The ticket is encrypted to prevent alteration or forgery, it contains IDC to indicate that it has been issued on behalf of C, ADC is needed to counter network address alterations and IDV enables V to determine if the message was correctly decrypted.

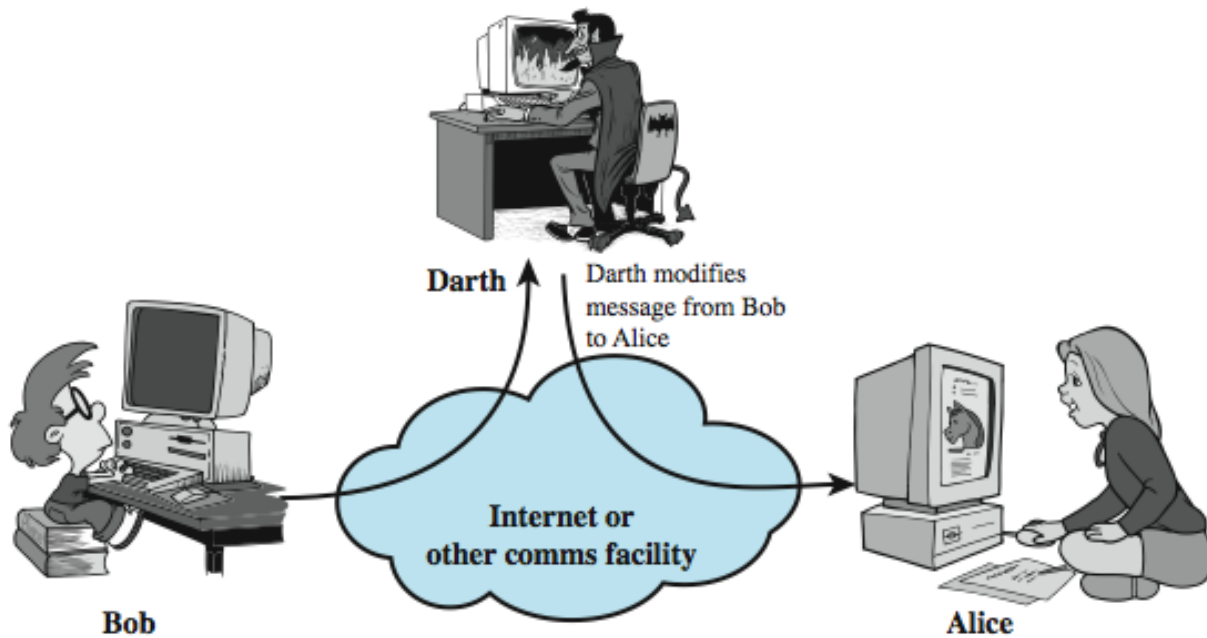
A More Secure Authentication Protocol

- Two major problems remain in previous simple protocol

10. In the context of Kerberos, what is a realm?

- A full-service Kerberos environment consisting of Kerberos server, a number of clients and a number of application servers requires the following:
 - (i) The Kerberos server has the user IDs and hashed passwords of all participant users. All users are registered with the Kerberos server.
 - (ii) The Kerberos server shares a secret key with each server. All servers are registered with the Kerberos server.
- Such an environment is referred to as Kerberos realm. Networks of clients and servers under different administrative organizations typically constitute different realms.
- Kerberos provides a mechanism for inter-realm authentication. If two realms support this, a third requirement is added
 - (iii) The Kerberos server in each interoperation realm shares a secret key with the server in the other realm. The two Kerberos servers are registered with each other.
- The use of multiple realms provides for the scalability of Kerberos.

11. Describe Man-in-the Middle Attack on Diffie-Hellman Key-Exchange Protocol.



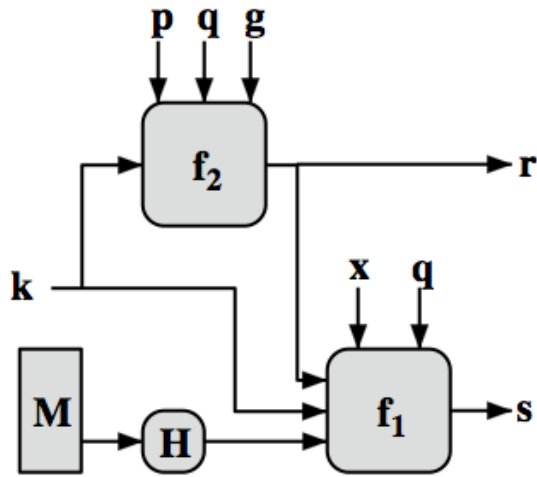
The protocol depicted in Figure 14.7 is insecure against an adversary who can intercept messages and then either relay the intercepted message or substitute another message (see Stallings Figure 1.3c). Such an attack is known as a **man-in-the-middle attack**. In this case, if an adversary, E, has control of the intervening communication channel, then E can compromise the communication in the following fashion without being detected:

1. A generates a public/private key pair $\{PU_a, PR_a\}$ and transmits a message intended for B consisting of PU_a and an identifier of A, IDA .
2. E intercepts the message, creates its own public/private key pair $\{PU_e, PR_e\}$ and transmits $PU_e || IDA$ to B.
3. B generates a secret key, K_s , and transmits $E(PU_e, K_s)$.
4. E intercepts the message and learns K_s by computing $D(PR_e, E(PU_e, K_s))$.
5. E transmits $E(PU_a, K_s)$ to A.

The result is that both A and B know K_s and are unaware that K_s has also been revealed to E. A and B can now exchange messages using K_s . E no longer actively interferes with the communications channel but simply eavesdrops. Knowing K_s , E can decrypt all messages, and both A and B are unaware of the problem. Thus, this simple protocol is only useful in an environment where the only threat is eavesdropping.

12. Write down the algorithm to perform DSS protocol

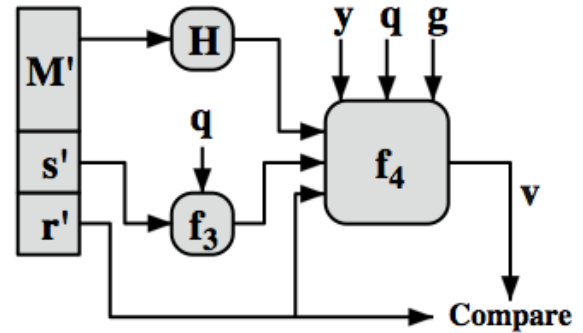
- have shared global public key values (p, q, g) :
 - a. choose 160-bit prime number q
 - b. choose a large prime p with $2^{L-1} < p < 2^L$
 - i. where $L = 512$ to 1024 bits and is a multiple of 64
 - ii. such that q is a 160 bit prime divisor of $(p-1)$
 - c. choose $g = h^{(p-1)/q}$
 - i. where $1 < h < p-1$ and $h^{(p-1)/q} \bmod p > 1$
- users choose private & compute public key:
 - a. choose random private key: $x < q$
 - b. compute public key: $y = g^x \bmod p$
- to sign a message M the sender:
 - a. generates a random signature key k , $k < q$
 - b. nb. k must be random, be destroyed after use, and never be reused
- then computes signature pair:
 - $r = (g^k \bmod p) \bmod q$
 - $s = [k^{-1}(H(M) + xr)] \bmod q$
- sends signature (r, s) with message M
- having received M & signature (r, s)
- to **verify** a signature, recipient computes:
 - $w = s^{-1} \bmod q$
 - $u1 = [H(M)w] \bmod q$
 - $u2 = (rw) \bmod q$
 - $v = [(g^{u1} y^{u2}) \bmod p] \bmod q$
- if $v = r$ then signature is verified
- see Appendix A for details of proof why



$$s = f_1(H(M), k, x, r, q) = (k^{-1} (H(M) + xr)) \bmod q$$

$$r = f_2(k, p, q, g) = (g^k \bmod p) \bmod q$$

(a) Signing



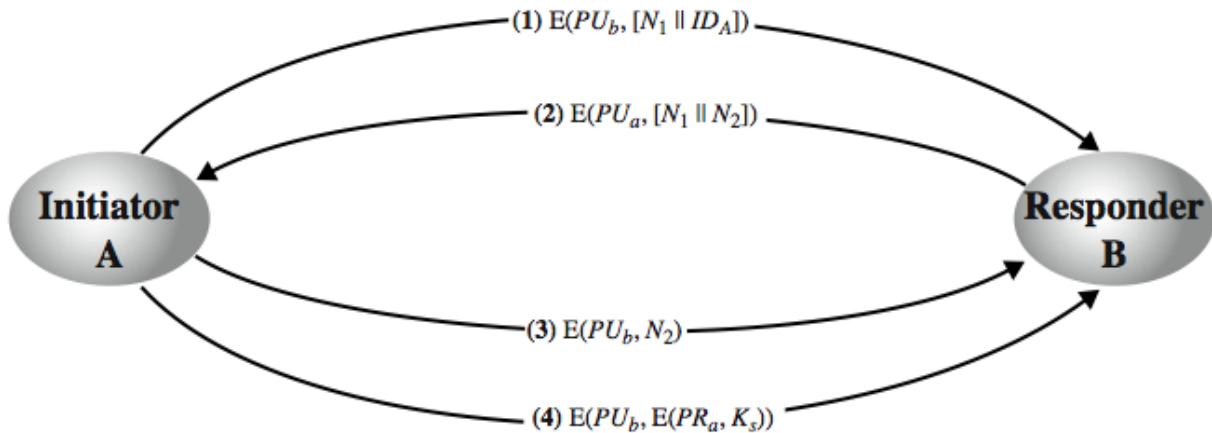
$$w = f_3(s', q) = (s')^{-1} \bmod q$$

$$v = f_4(y, q, g, H(M'), w, r')$$

$$= ((g^{H(M')w} \bmod q) y^{r'w} \bmod q) \bmod p \bmod q$$

(b) Verifying

13. Describe a secret key distribution scenario with confidentiality and authentication



Stallings Figure 14.8, based on an approach suggested in [NEED78], provides protection against both active and passive attacks. Assuming A and B have exchanged public keys by one of the schemes described subsequently in this chapter, then the following steps occur:

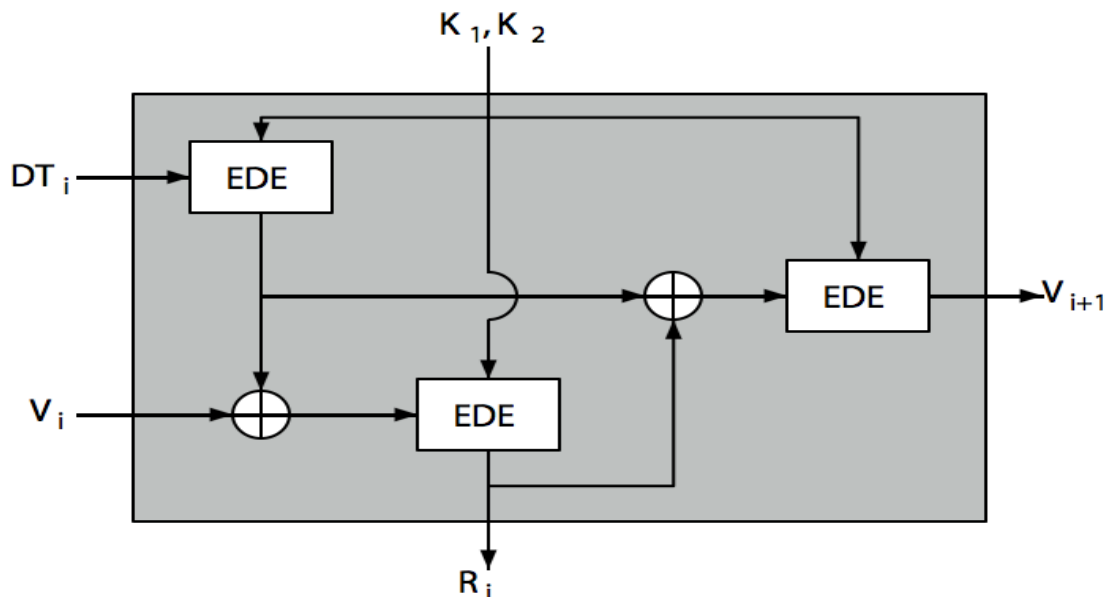
1. A uses B's public key to encrypt a message to B containing an identifier of A (IA) and a nonce (N1), which is used to identify this transaction uniquely.
2. B sends a message to A encrypted with PU_a and containing A's nonce (N1) as well as a new nonce generated by B (N2). Because only B could have decrypted message (1), the presence of N1 in message (2) assures A that the correspondent is B.
3. A returns N2, encrypted using B's public key, to assure B that its correspondent is A.

4. A selects a secret key K_s and sends $M = E(PU_b, E(PR_a, K_s))$ to B. Encryption with B's public key ensures that only B can read it; encryption with A's private key ensures that only A could have sent it.
 5. B computes $D(PU_a, D(PR_b, M))$ to recover the secret key.
- The result is that this scheme ensures both confidentiality and authentication in the exchange of a secret key.

14. Compare between CBC and CTR mode of operation.

CBC	CTR
Padding needed	No padding
No parallel processing	Parallel processing
Separate encryption and decryption functions	Encryption function alone is enough
Random IV or a nonce	Unique nonce
Nonce reuse leaks some information about initial plaintext block	Nonce reuse will leak information about the entire message

15. Describe ANSI X9.17 PRG.



One of the strongest (cryptographically speaking) PRNGs is specified in ANSI X9.17. It uses date/time & seed inputs and 3 triple-DES encryptions to generate a new seed & random value. See discussion & illustration in Stallings section 7.4 & Figure 7.14 where:

DTi - Date/time value at the beginning of ith generation stage

 V_i - Seed value at the beginning of i th generation stage

Ri - Pseudorandom number produced by the ith generation stage

K1, K2 - DES keys used for each stage

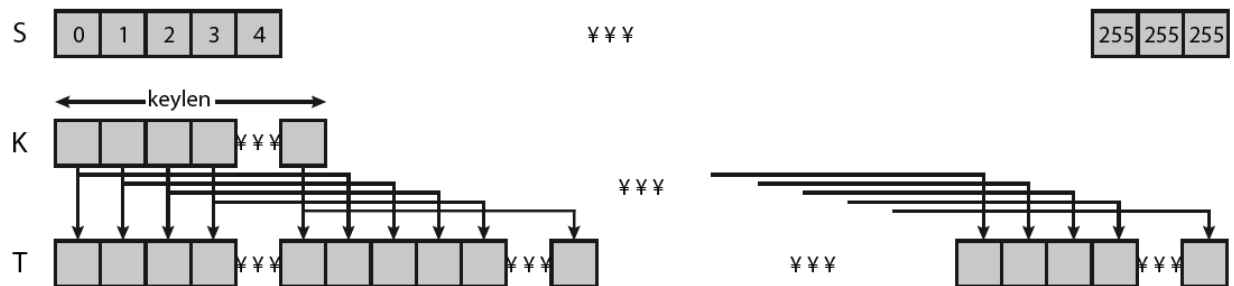
Then compute successive values as:

$$R_i = \text{EDE}([K1, K2], [V_i \text{ XOR } \text{EDE}([K1, K2], DT_i)])$$

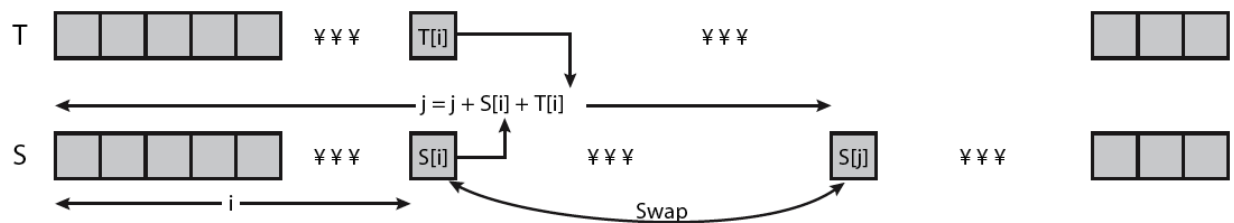
$$V_{i+1} = \text{EDE}([K1, K2], [R_i \text{ XOR } \text{EDE}([K1, K2], DT_i)])$$

Several factors contribute to the cryptographic strength of this method. The technique involves a 112-bit key and three EDE encryptions for a total of nine DES encryptions. The scheme is driven by two pseudorandom inputs, the date and time value, and a seed produced by the generator that is distinct from the pseudo-random number produced by the generator. Thus the amount of material that must be compromised by an opponent is overwhelming.

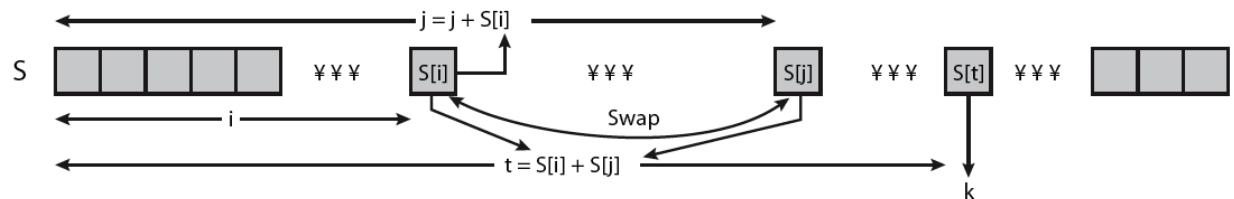
16. Describe RC4 Stream Generator.



(a) Initial state of S and T

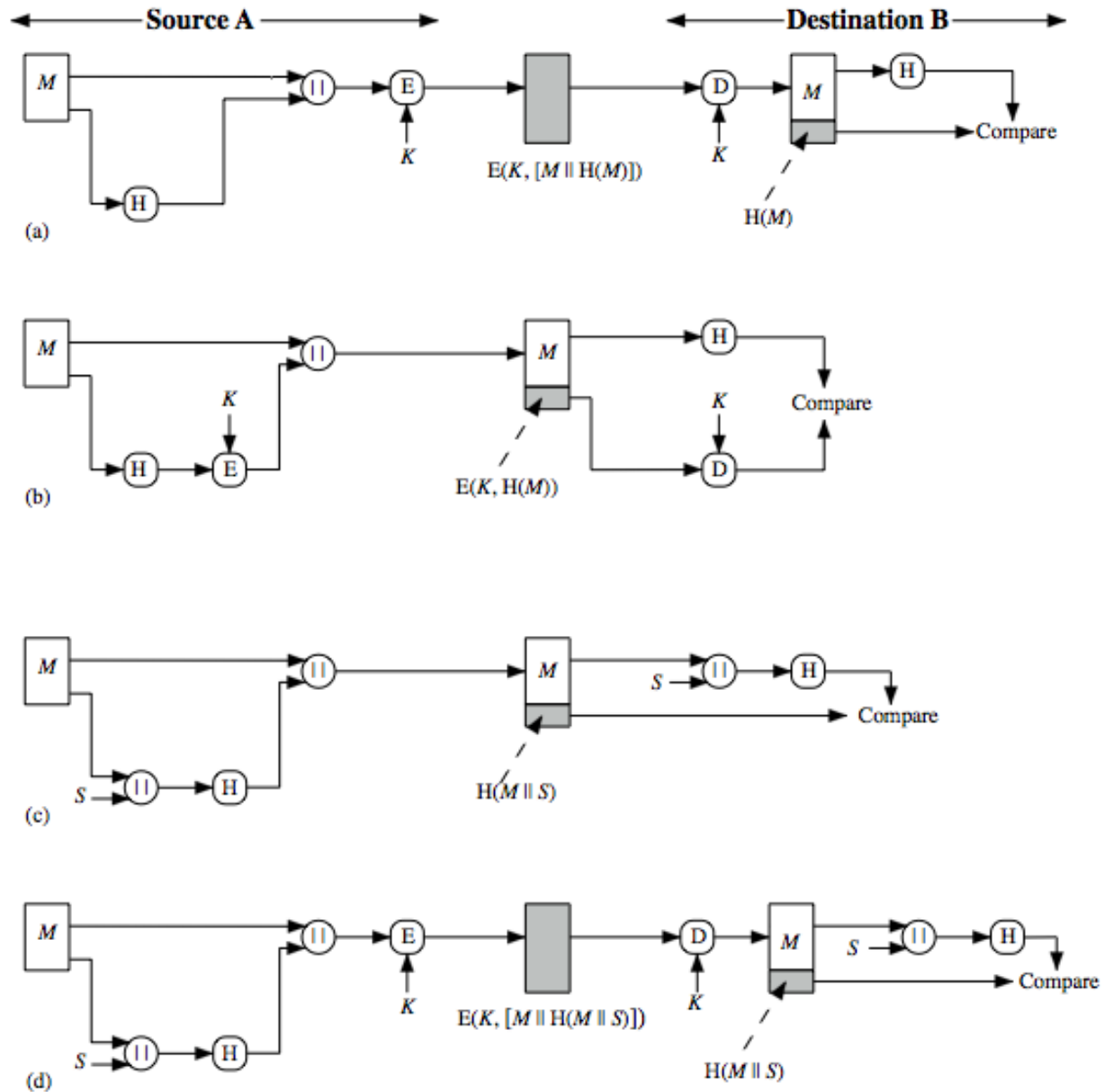


(b) Initial permutation of S



(c) Stream Generation

17. Discuss the various process of message authentication using Hash functions.



Message authentication is a mechanism or service used to verify the integrity of a message, by assuring that the data received are exactly as sent. Hash code can be used to provide message authentication, as follows:

- The message plus concatenated hash code is encrypted using symmetric encryption. Since only A and B share the secret key, the message must have come from A and has not been altered. The hash code provides the structure or redundancy required to achieve authentication.
- Only the hash code is encrypted, using symmetric encryption. This reduces the processing burden for those applications not requiring confidentiality.
- Shows the use of a hash function but no encryption for message authentication. The technique assumes that the two communicating parties share a common secret value S . A

computes the hash value over the concatenation of M and S and appends the resulting hash value to M. Because B possesses S, it can recompute the hash value to verify. Because the secret value itself is not sent, an opponent cannot modify an intercepted message and cannot generate a false message.

- d. Confidentiality can be added to the approach of (c) by encrypting the entire message plus the hash code.

When confidentiality is not required, method (b) has an advantage over methods (a) and (d), which encrypts the entire message, in that less computation is required.

18. Write short notes on Hill Cipher

- takes m successive plaintext letters and substitutes for them m ciphertext letters
- substitution determined by m linear equations, $C = KP \pmod{26}$
- This example will rely on some linear algebra and some number theory. The 'key' for a hill cipher is a matrix e.g

$$- \begin{bmatrix} 2 & 4 & 5 \\ 9 & 2 & 1 \\ 3 & 8 & 7 \end{bmatrix}$$

19. Write short notes on the following topics

a. Session Key and Master Key

Session key

- temporary key
- used for encryption of data between users
- for one logical session then discarded

Master key

- used to encrypt session keys
- shared by user & key distribution center

b. Avalanche effect of DES structure

A desirable property of any encryption algorithm is that a small change in either the plaintext or the key should produce a significant change in the ciphertext. In particular, a change in one bit of the plaintext or one bit of the key should produce a change in many bits of the ciphertext. If the change were small, this might provide a way to reduce the size of the plaintext or key space to be searched.

c. Euler Totient Function

- when doing arithmetic modulo n
- complete set of residues is: $0..n-1$
- reduced set of residues is those numbers (residues) which are relatively prime to n
 - eg for $n=10$,
 - complete set of residues is $\{0,1,2,3,4,5,6,7,8,9\}$
 - reduced set of residues is $\{1,3,7,9\}$
- number of elements in reduced set of residues is called the Euler Totient Function $\phi(n)$

d. One Time Pad

In cryptography, a one-time pad is a system in which a private key generated randomly is used only once to encrypt a message that is then decrypted by the receiver using a matching one-time pad and key.

Or

A key used in private-key cryptography that is the same length as the contents of the message being encrypted, providing unbreakable encryption if the key is perfectly random and used only once.

e. Hash Function

A hash function H accepts a variable-length block of data M as input and produces a fixed-size hash value $h = H(M)$. A "good" hash function has the property that the results of applying the function to a large set of inputs will produce outputs that are evenly distributed, and apparently random.